



LOST BOYS CYBER

THREAT INTELLIGENCE • MALWARE ANALYSIS • DETECTION ENGINEERING



CVE-2026-5545 wrong reuse of HTTP Negotiate connection

Vulnerability Report

Classification	TLP:CLEAR
Published	2026-06-14
Version	1.0
Author	Lost Boys Cyber
Report Type	Vulnerability Report

TLP:CLEAR | Lost Boys Cyber | CVE-2026-5545 wrong reuse of HTTP Negotiate connection - Vulnerability Report

Published: 2026-06-14 | TLP:CLEAR | Version: 1.0 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

Table of Contents

1. Executive Summary
2. Intelligence Requirement
3. Source Review and Confidence
4. Key Findings
5. Threat Context
6. Detection and Hunting
7. Recommendations
8. References

CVE-2026-5545 wrong reuse of HTTP Negotiate connection

1. Executive Summary

CVE-2026-5545 is a curl and libcurl authentication-bypass flaw in HTTP connection reuse logic for Negotiate-authenticated traffic. The curl advisory states that after a client authenticates to a host with HTTP Negotiate using one credential set, a later authenticated request to the same host can incorrectly reuse that existing connection even when the second operation is intended to run as a different user. In effect, the second request may execute over a connection that is still authenticated as the first user.

This is not a broad unauthenticated internet-edge remote code execution issue. It requires a narrower sequence: a vulnerable curl/libcurl build, connection reuse still in scope, the same destination host, and a workflow that performs multiple authenticated operations with different credentials while the prior Negotiate-authenticated connection remains alive. Even so, the impact can be operationally serious in environments that rely on Negotiate, SPNEGO, Kerberos, or related enterprise SSO patterns for authorization separation across internal web applications, APIs, proxies, or management interfaces.

The main defender concern is trust-boundary confusion rather than malware delivery. If an application believes a second HTTP(S) request is running under `user2` but libcurl silently reuses a connection authenticated as `user1`, downstream authorization decisions, audit trails, and data-access assumptions can break. Depending on the target workflow, the result may be unauthorized reads, unintended writes, or cross-user action execution under the wrong identity.

Remediation is straightforward: upgrade to curl/libcurl 8.20.0 or deploy an equivalent vendor backport. If patching cannot happen immediately, application owners should disable or sharply limit connection reuse in Negotiate-authenticated workflows and validate any systems that rotate credentials against the same host within one process or connection pool. Detection and hunting should focus on exposure discovery, Negotiate usage by curl-based tooling, and multi-credential same-host request patterns rather than IOC matching.

2. Intelligence Requirement

This report addresses the following intelligence requirement: what does CVE-2026-5545 mean for defenders using curl or libcurl in enterprise HTTP authentication workflows, which environments are meaningfully exposed, how credible is exploitation risk, and what remediation, detection, and hunting actions should be prioritized first?

Question	Assessment
What is the flaw?	A later HTTP(S) request can be sent over a previously Negotiate-authenticated connection to the same host even when the application intended to use different credentials.
Which authentication mode matters?	HTTP Negotiate, typically associated with SPNEGO/Kerberos and some enterprise SSO deployments.
What must happen first?	A prior Negotiate-authenticated connection must still be alive, then a second authenticated operation to the same host must occur with different credentials or identity expectations.
What is the primary impact?	Authorization confusion and potential authentication bypass, with downstream confidentiality and integrity impact depending on what the first user is allowed to access or modify.
Which versions are affected?	curl/libcurl 7.10.6 through 8.19.0 according to the vendor advisory and vendor JSON.
What fixes the issue?	curl/libcurl 8.20.0 or equivalent vendor backports; temporary mitigations include disabling or constraining connection reuse in affected workflows.

Is active exploitation confirmed?	No authoritative evidence of in-the-wild exploitation was identified in the reviewed vendor, NVD, Openwall, Debian, OpenCVE, or MSRC-linked material.
Which environments deserve highest priority?	Applications and services using libcurl with HTTP Negotiate against IIS, SharePoint, Exchange, intranet APIs, proxies, or custom enterprise web services where multiple identities may target the same host in one process.

3. Source Review and Confidence

Source	Contribution	Confidence
curl security advisory (`CVE-2026-5545.html`)	Canonical flaw description, trigger sequence, affected versions, fixed version, and mitigation guidance	High
curl JSON advisory (`CVE-2026-5545.json`)	Machine-readable version ranges, CWE mapping, publication timeline, and fix commit references	High
NVD CVE record	CVSS 3.1 vector, affected CPE range, and normalized severity view	High
Openwall oss-security advisory mirror	Independent republication of upstream advisory and disclosure-timing corroboration	High
Debian Security Tracker	Downstream package-tracking context and backport/triage caveats for Linux estates	High
OpenCVE enrichment page	EPSS, KEV status, and visibility into differing CNA/enrichment interpretations	Medium
Microsoft Security Update Guide intake item	Discovery path for this workflow; useful as syndication context only, not the primary technical source	Medium

Assessment confidence is high for the core technical conclusions because the upstream curl advisory, structured vendor JSON, NVD enrichment, Openwall republication, and Debian downstream tracking all align on the same vulnerability mechanics and affected version range. Confidence is medium for exploitation prevalence because the reviewed public sources did not provide authoritative incident reporting, KEV inclusion, or campaign attribution.

Two caveats matter for defenders. First, the flaw is conditional rather than universal: it depends on HTTP Negotiate usage and on connection reuse across multiple same-host authenticated operations. Second, version strings alone are not always enough for triage because downstream Linux and appliance vendors may backport the fix without matching upstream numbering exactly; product owners should validate vendor package advisories before concluding a host is still vulnerable.

4.1 Vulnerability metadata

Field	Value
CVE	CVE-2026-5545
Product family	curl and libcurl
Vulnerable behavior	Incorrect reuse of a previously Negotiate-authenticated HTTP(S) connection for a later request intended to run under different

	credentials
Affected protocol surface	HTTP and HTTPS workflows using Negotiate authentication
Weakness	Vendor: CWE-305 Authentication Bypass by Primary Weakness; NVD enrichment also lists CWE-613; downstream enrichment may map related identity-mismatch interpretations such as CWE-488
Vendor severity	Medium
NVD severity	CVSS v3.1 6.5 / Medium
NVD CVSS vector	`AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:H/A:N`
Alternate enrichment vector observed	`AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:H/A:N` on OpenCVE secondary data; treat as supporting context, not the primary score of record
Affected versions	curl/libcurl 7.10.6 through 8.19.0
Fixed version	curl/libcurl 8.20.0
Introduced by	curl commit `e56ae1426cb7a0a4a427cf8d6099a821fdaae428`
Fixed by	curl commit `33e43985b8f3b9e66691d06e70be0395849856cd`
Published by curl	2026-04-29
CVE publication	2026-05-13
EPSS	0.00036 according to OpenCVE enrichment reviewed on 2026-06-14
KEV status	Not listed in CISA KEV in reviewed public sources
Exploitation status	No authoritative public confirmation of in-the-wild exploitation identified during this review

4.2 Flaw mechanics

The defect sits in client-side connection-pool reuse logic rather than in HTTP authentication standards themselves. According to curl, when reusing a connection a number of criteria must be satisfied before an existing connection is selected. Due to a logical error, a request could wrongfully reuse an existing connection to the same server that had already been authenticated with different credentials.

The vendor example is the most useful way to think about impact: an application first authenticates to a server with Negotiate using `user1:password1`, then later performs another operation to the same host while intending to use `user2:password2`. If the earlier connection remains alive, the second request can mistakenly ride the first authenticated connection. The application may believe it is using a different identity, but the server-side session/connection state still reflects the original user.

This makes the issue especially relevant to software that performs multiple authenticated operations inside a shared libcurl context, worker process, long-running service, or automation pipeline. The risk is lower in simple one-shot workflows that do not reuse connections or that never rotate identities against the same host.

4.3 Exposure profile

Exposure pattern	Why it matters	Priority
------------------	----------------	----------

Enterprise applications embedding libcurl for Negotiate-authenticated API or web requests	The vulnerable logic can be hidden inside higher-level business software or middleware rather than obvious CLI use	Immediate
Services that talk to the same IIS, SharePoint, Exchange, or intranet API endpoint using multiple identities	Closely matches the vendor-described same-host, multi-credential trigger condition	Immediate
Long-lived worker processes, integration middleware, and automation daemons with shared connection pools	Increase the chance that a prior authenticated connection remains alive long enough to be wrongly reused	High
Security or IT tooling that assumes per-request identity separation for delegated or impersonated actions	Wrong-identity execution can corrupt audit expectations and authorization boundaries	High
Linux and appliance estates triaged only by version string without vendor-backport awareness	Can produce false positives or false negatives during remediation reporting	Medium
HTTP clients that never use Negotiate or never reuse connections across identities	Outside the practical trigger surface described by the vendor	Reduced

4.4 Defensive meaning and ATT&CK mapping

ATT&CK mapping for this CVE should remain narrow and defensive. The flaw is not malware tradecraft by itself; it is an authentication-state confusion bug that can benefit an on-path or application-level abuse scenario where identity separation matters.

ATT&CK ID	Technique	Rationale
T1078	Valid Accounts	The flaw can cause a request to execute under a previously authenticated valid account rather than the identity expected by the application.
T1550	Use Alternate Authentication Material	Negotiate-authenticated connection state is effectively carried forward in a way the application did not intend, creating an identity-context mix-up.
T1190	Exploit Public-Facing Application	Relevant only where vulnerable libcurl-backed services expose Negotiate-authenticated web workflows to external or semi-external users.
T1530	Data from Cloud Storage Object	Conditional mapping for API-backed SaaS or document platforms where the wrong authenticated identity could read protected data; use only when the business workflow supports it.

4.5 Validation status

No local exploit reproduction or lab packet capture was performed during this task. This report is based on reviewed vendor and downstream public sources. Confidence is high in the scope, affected versions, and remediation guidance, but medium regarding exploit prevalence because reviewed sources did not include authoritative campaign reporting or incident case studies.

5. Threat Context

CVE-2026-5545 is best understood as an identity-separation and authorization-boundary problem inside enterprise HTTP client workflows. It is less likely to drive opportunistic mass exploitation than a pre-authentication RCE, but it can still be important in real environments because Negotiate is often used exactly where organizations care about role separation, delegated access, and single sign-on trust.

Where the flaw becomes meaningful is in stateful software that talks to the same host on behalf of multiple users, service accounts, or delegated identities. If a vulnerable process assumes a new request cleanly represents a new identity while libcurl reuses an older Negotiate-authenticated connection, the resulting action can run with the wrong security context. Depending on the application, that may expose private data, trigger writes under the wrong account, or create confusing audit evidence that slows incident response.

5.1 Representative attack and failure scenarios

Scenario	Description	Defensive meaning
Multi-user API broker	A middleware service handles requests for multiple users against the same Negotiate-protected backend and reuses a shared libcurl context	Review connection-pool isolation and per-user request handling immediately
Administrative automation	An orchestration script or service rotates credentials while calling the same host for privileged and non-privileged operations	Validate that privileged operations cannot inherit prior lower- or higher-privilege connection state
Intranet portal integration	SharePoint, IIS, or custom internal web applications rely on Negotiate for SSO-backed actions and audit accountability	Wrong-identity execution can create both access-control and forensic-traceability problems
Shared service account workflows	Background jobs impersonate or test multiple identities against one endpoint to verify entitlement or retrieve per-user data	Exposure may hide inside QA, sync, migration, backup, or compliance jobs rather than obvious end-user applications

5.2 Exploitation-status assessment

The reviewed public record does not support a high-confidence claim of active exploitation. OpenCVE showed EPSS at `0.00036` and no KEV inclusion, while the vendor and downstream sources focused on patching and workflow impact rather than emergency exploitation reporting. NVD still rates the issue Medium because the resulting authorization confusion can have meaningful impact when the preconditions line up.

That combination should lower panic, but not response discipline. The flaw directly affects identity assurance in environments where Negotiate is used to separate user actions on sensitive backends. Even absent public campaign reporting, organizations should treat vulnerable multi-identity workflows as worth patching promptly and validating carefully.

5.3 Exposure-reduction priorities

Exposure driver	Why it increases risk	Defensive priority
HTTP Negotiate enabled in curl/libcurl-backed applications	Supplies the required authentication mode	Highest
Same-host requests made under multiple identities within one process or connection pool	Matches the explicit trigger sequence described by curl	Highest
Long-lived services with pooled connections	Increase the chance that a previously authenticated connection remains reusable	High

Embedded libcurl dependencies with weak software inventory	Makes exposure easy to miss during triage	High
Reliance on audit logs that assume one request equals one intended identity	Wrong-identity execution can mislead detection and incident review	Medium

6. Detection and Hunting

This CVE is better suited to exposure management, application workflow review, and behavioral hunting than to classic IOC-led detection. There are no stable attacker domains, hashes, or infrastructure indicators in the reviewed source set. Defenders should instead identify vulnerable curl/libcurl versions, discover where Negotiate authentication is in use, and hunt for same-host multi-credential request patterns or software designs that reuse connections across identities.

6.1 Detection coverage summary

Signal	Telemetry source	Analytic goal	Coverage caveat
Installed curl/libcurl version below fixed or backported level	Package inventory, EDR software inventory, SBOM data	Find systems that may still contain vulnerable code	Requires vendor-backport awareness
Process usage of `curl` or `curl.exe` with `--negotiate`, `--anyauth`, or explicit credential options	EDR process creation logs, shell history, command-line telemetry	Identify obvious CLI workflows that may exercise the vulnerable surface	Misses embedded libcurl use without visible CLI invocation
Repeated HTTP(S) requests from one process to the same host under different usernames or service accounts	Proxy logs, application logs, EDR network telemetry, custom app logging	Surface workflow patterns consistent with the vulnerability preconditions	Often requires app-specific context or enriched logging
Long-lived services that call Negotiate-protected endpoints on behalf of multiple principals	SBOM, config review, service inventory, source-code review	Prioritize likely exposure even when direct telemetry is thin	Requires engineering collaboration, not pure SOC telemetry

6.2 Sigma - suspicious Negotiate curl usage on endpoints

<pre> title: curl Negotiate Authentication Usage That May Require CVE-2026-5545 Exposure Review id: c1fef12a-7478-4e0e-9c42-b91d3319f7db status: experimental description: Detects curl or curl.exe executions that use Negotiate-related HTTP authentication options and may warrant review for CVE-2026-5545 exposure in multi-credential same-host workflows. author: Lost Boys Cyber date: 2026-06-14 references: - https://curl.se/docs/CVE-2026-5545.html - https://nvd.nist.gov/vuln/detail/CVE-2026-5545 logsource: category: process_creation product: windows detection: image: Image endswith: - '\curl.exe' - '\curl.exe.mui' negotiate: CommandLine contains: - '--negotiate' - 'CURLAUTH_NEGOTIATE' - '--anyauth' auth_context: CommandLine contains: </pre>
--


```

- 'http://'
- 'https://'
- '-u '
- '--user '
condition: image and negotiate and auth_context
falsepositives:
- Legitimate administrative scripting with Negotiate-authenticated web services
- Security-team validation or troubleshooting
level: medium
tags:
- attack.t1078
- attack.t1550

```

Linux estates should adapt the same logic to `Image|endswith: '/curl'` and their available shell, auditd, or EDR process telemetry fields.

6.3 KQL - inventory potentially exposed curl/libcurl usage

```

let lookback = 30d;
let processHits = DeviceProcessEvents
| where Timestamp > ago(lookback)
| where FileName in~ ("curl", "curl.exe")
| where ProcessCommandLine has_any ("--negotiate", "--anyauth", "http://", "https://")
| project Timestamp, DeviceName, AccountName, FileName, ProcessCommandLine, InitiatingProcessFileName, InitiatingProcessCommandLine;
let softwareHits = DeviceTvmSoftwareInventory
| where SoftwareName has_any ("curl", "libcurl")
| project DeviceName, SoftwareName, SoftwareVersion, Vendor;
processHits
| join kind=leftouter softwareHits on DeviceName
| order by Timestamp desc

```

6.4 KQL - same-host multi-credential hunting aid

```

let lookback = 30d;
let interestingProcesses = DeviceProcessEvents
| where Timestamp > ago(lookback)
| where FileName in~ ("curl", "curl.exe") or ProcessCommandLine has_any ("--negotiate", "CURLAUTH_NEGOTIATE")
| project ProcTime=Timestamp, DeviceName, ProcessId, FileName, ProcessCommandLine, AccountName;
let net = DeviceNetworkEvents
| where Timestamp > ago(lookback)
| where Protocol =~ "Tcp"
| where RemoteUrl != "" or isnotempty(RemoteIP)
| project NetTime=Timestamp, DeviceName, InitiatingProcessId, InitiatingProcessFileName, InitiatingProcessCommandLine, RemoteUrl, RemoteIP, RemotePort;
interestingProcesses
| join kind=inner net on DeviceName
| where InitiatingProcessId == ProcessId
| summarize FirstSeen=min(NetTime), LastSeen=max(NetTime), DistinctAccounts=dcnt(AccountName), Accounts=make_set(AccountName, 10), Commands=make_set(ProcessCommandLine, 10) by DeviceName, coalesce(RemoteUrl, tostring(RemoteIP)), InitiatingProcessFileName
| where DistinctAccounts > 1
| order by LastSeen desc

```

The second query is a hunting aid rather than a direct exploit detector. It is intended to find hosts or processes that appear to contact the same destination under multiple account contexts and therefore deserve application-level review.

6.5 Threat-hunting hypotheses

Hypothesis	What to prove or disprove
Some applications use libcurl with Negotiate on behalf of multiple users against the same host	Review source, configs, proxy logs, and service design to identify shared connection-pool risk

Exposed workflows are concentrated in internal enterprise integrations rather than internet-facing web apps	Map Negotiate usage to intranet APIs, SharePoint, Exchange, IIS, proxies, and custom line-of-business services
CLI evidence understates true exposure because most use is embedded in applications	Cross-reference package inventory, SBOMs, application manifests, and developer ownership data
Risk is highest in long-lived workers or integration daemons that rotate identities without isolating libcurl state	Examine worker models, connection reuse settings, and account-switching logic in code or runtime configs

No stable attacker-controlled IOC set was identified from the reviewed sources. Treat this as a vulnerability-management and application-architecture hunting problem, not a signature-driven campaign hunt.

7. Recommendations

Priority	Owner	Action	Rationale
Immediate	Platform / endpoint engineering	Upgrade curl and libcurl to 8.20.0 or deploy vendor backports that remediate CVE-2026-5545	Removes the flawed connection-reuse behavior
Immediate	Application owners	Identify every workflow that uses HTTP Negotiate through curl/libcurl, including embedded dependencies and shared worker pools	The affected surface is authentication- and workflow-specific rather than universally visible
Immediate	Development teams	Disable or constrain connection reuse for Negotiate-authenticated operations when patching cannot happen immediately	Reduces practical exposure until a fixed build is deployed
High	Security engineering	Add software-inventory and process-detection coverage for curl/libcurl plus Negotiate-related command-line or dependency usage	Best available way to locate exposed estates quickly
High	IAM / application teams	Validate that multi-user or impersonation workflows isolate connection state per identity when calling the same host	Prevents wrong-identity request execution and audit confusion
Medium	Vulnerability management	Account for distro and appliance backports before marking Linux or embedded products as vulnerable or remediated	Prevents noisy false positives and missed exceptions
Medium	SOC / detection engineering	Hunt for same-host multi-credential request patterns in long-lived services and integration middleware	Helps prioritize the highest-risk workflows for engineering review
Low	Architecture / modernization	Prefer designs that minimize credential switching inside	Reduces recurrence of identity-

		shared HTTP client contexts and that log explicit per-request identity selection	state confusion bugs over time
--	--	--	--------------------------------

Recommended execution order:

- 1. Inventory curl/libcurl versions and Negotiate usage across applications, middleware, and automation.
- 2. Patch or backport affected systems to 8.20.0-equivalent builds, prioritizing multi-identity same-host workflows.
- 3. Apply temporary mitigations by disabling or limiting connection reuse in Negotiate-authenticated paths where patching lags.
- 4. Validate that shared services, brokers, and integration workers isolate request identity and connection state correctly.
- 5. Hunt for Negotiate-enabled curl usage and same-host multi-account patterns to identify residual blind spots.

8. References

- 1. curl Security Advisory, `CVE-2026-5545: wrong reuse of HTTP Negotiate connection` - <https://curl.se/docs/CVE-2026-5545.html>
- 2. curl machine-readable advisory JSON, `CVE-2026-5545.json` - <https://curl.se/docs/CVE-2026-5545.json>
- 3. NVD CVE record, `CVE-2026-5545` - <https://nvd.nist.gov/vuln/detail/CVE-2026-5545>
- 4. Openwall oss-security advisory mirror, `[ADVISORY] curl: CVE-2026-5545: wrong reuse of HTTP Negotiate connection` - <https://www.openwall.com/lists/oss-security/2026/04/29/8>
- 5. Debian Security Tracker, `CVE-2026-5545` - <https://security-tracker.debian.org/tracker/CVE-2026-5545>
- 6. OpenCVE enrichment page, `CVE-2026-5545` - <https://app.opencve.io/cve/CVE-2026-5545>
- 7. Microsoft Security Update Guide syndication entry - <https://msrc.microsoft.com/update-guide/vulnerability/CVE-2026-5545>